

보안 인프라 구성을 통한 IT 침해사고 대비 체계 구축 및 활용

무료 음원 스트리밍 및 다운로드 웹 서비스
플랫폼



DATE. 2025.06.11

TEAM. 3조 소리곳간

AUTHOR. 강인석 | 남소현 | 최현일

목 차



I 프로젝트 개요

1. 프로젝트 목적
2. 프로젝트 배경
3. 프로젝트 구축 조직도
4. 프로젝트 조직 역할 정의
5. 전체 추진 일정

IV 보안 시스템 고도화

1. WAF 및 방화벽 적용
2. Splunk 대시보드 구성

II 아키텍처 설계

1. 시스템 구성도
2. 주요 컴포넌트 설명
3. 기술 스택
4. 설계 원칙
5. 보안 설계 정의
6. 아키텍처 구성도

V 검증 결과 및 로그 분석

1. 공격 시나리오 설정
2. 공격 시도 및 탐지 결과
3. 한계점 및 대응 방안

III 시스템 구축

1. OS 및 환경 구축
2. 웹서비스 센터 구축
3. 관리자 센터 구축

VI 회고 및 총평

1. 기술적 개선 및 확장 방향
2. 팀원별 회고

I 프로젝트 개요



1

프로젝트 목적

본 프로젝트는 무료 음원 스트리밍 및 다운로드 웹 서비스를 구축하고, 이를 실습 기반의 보안 교육 플랫폼으로 활용하여 실제 보안 위협 시나리오를 재현하고 방어 체계를 직접 설계·검증하는 것을 목적으로 하였습니다.

단순한 이론 중심이 아닌 실무 수준의 인프라(Apache, Spring Boot, MariaDB, MinIO 등)와 공격자 환경(Kali Linux)을 모두 구성하고, 웹 보안의 핵심 위협 요소(SQL Injection, XSS, 인증 우회 등)를 실습하며 실시간 로그 분석 및 WAF/IDS 기반 대응 체계를 마련함으로써, 실전형 보안 전문가로서의 역량을 기를 수 있는 기반을 마련하였습니다.

음원 스트리밍 서비스 구축을 통해 실질적인 보안 위협 시나리오를 실습하고
이를 기반으로 방어 체계를 설계·검증할 수 있는 보안 전문가로 성장

무료 음원
스트리밍
웹서비스 구축

- 회원가입, 로그인, 음원 검색, 재생, 다운로드 기능 포함
- Spring Boot, MariaDB, Flask 등 실무 환경 구성
- 개발 단계에서 보안 요소 반영 (암호화, 접근제어)

실제 보안
위협 시나리오
실습

- SQL Injection, XSS, 인증 우회, Presigned URL 재사용 등
- 공격자 환경 구성 (Kali Linux 기반)
- 공격 로그 실시간 분석 (Splunk 연동)

보안 방어 체계
설계 및 검증

- 시나리오 기반의 대응 전략 설계
- IDS/IPS(WAF, Snort 등) 구성 및 탐지 확인
- 로그 기반 이상 징후 식별 및 대응방안 도출

2

프로젝트 배경

배경:

기존 국내 음원 플랫폼의 기술적 한계점.

- ◆ 복잡한 로열티 구조
- ◆ 느린 반응 속도
- ◆ 높은 트래픽 처리 비용

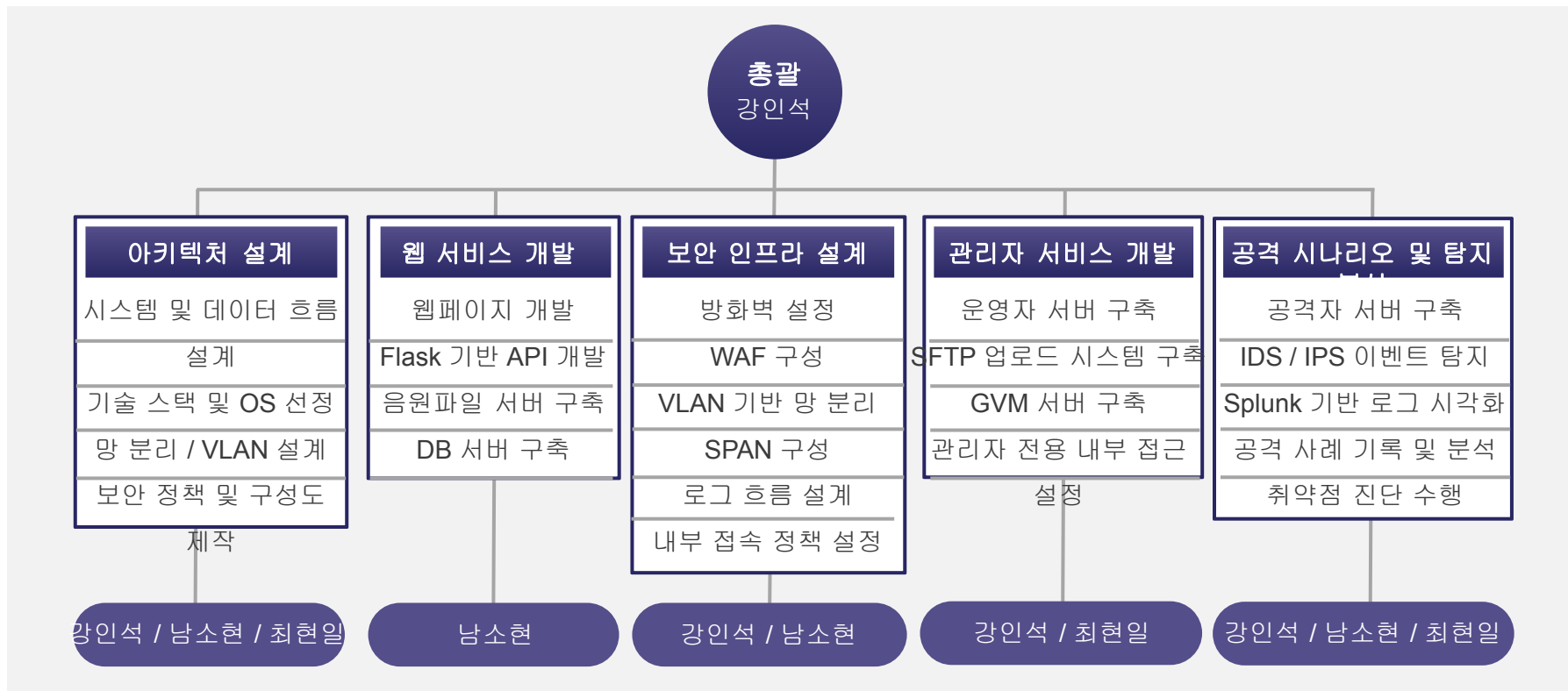
특히 **K-POP** 등 한국 음악의 글로벌 수요가 급증하면서, 대규모 사용자 트래픽을 안정적으로 처리할 수 있는 고신뢰·고가용성 시스템의 필요성이 더욱 부각되고 있고 클라우드 기반의 독립적인 스트리밍 플랫폼이 각광받는 가운데, 보안 위협에 대한 실질적인 대응 역량도 함께 요구.

목표:

본 프로젝트는 이러한 배경을 바탕으로, 실제 음원 스트리밍 웹 서비스를 구축하고, 그 위에서 발생 가능한 보안 위협 시나리오를 실습·분석하며 방어 체계를 직접 설계·검증함으로써, 기술적 완성도와 보안 대응 능력을 동시에 갖춘 차세대 음악 플랫폼 아키텍처를 구현을 목표.

3

프로젝트 구축 조직도



4

프로젝트 조직 역할
정의

이름	역할	세부 역할
강인석	• 네트워크 망 분리 • 로그 설정	• B 센터 아키텍처 구성도 및 시스템 흐름도 작성 • 물리적/논리적 망분리 • A-B센터간 IPsec VPN 연동
남소현	• WEB 서버 / API 서버 / DB 서버 / NFS 서버 구축 • DNS / WAF / 웹 서비스 방화벽 / A 센터 Snort 설정 • Splunk 로그 연동 및 대시보드 • 웹 공격 실행 및 탐지, 웹서버 보완	• A 센터 아키텍처 구성도 작성 • springboot 기반 음악 재생 및 다운로드 기능 포함된 웹페이지 구축 • 음원메타데이터 및 회원정보를 가진 데이터베이스 구축 • Flask기반의 백엔드 구현 • HTTPS 리디렉션 설정 및 API 프록시 설정 • 시스템 상태 및 URL 요청, 특정 공격 이벤트 탐지 대시보드 • 비밀번호 해싱, SQL Injection 방지, 사용자 검증 로직
최현일	• SFTP서버 • 관리자용 내부 운영환경 구성 • Kali Linux 구축 • 서비스 보안 설계 • Splunk 대시보드 작성	• SFTP 기반 음원 보안 전송 환경 설계 및 구축 • 관리자용 내부/외부 운영환경 구성 • Kali Linux 공격 환경 2대 구성 및 공격 시나리오 실습 • 서비스 보안 아키텍처 설계 및 정책 • Splunk 기반 로그 및 이상행위 분석

5

단계별 수행 절차

구분	주요 업무 내용	기간	비고
1단계	요구사항 분석 및 설계	2025-05-20 ~ 2025-05-20	프로젝트 방향 설정 및 아키텍처 설계
2단계	인프라 구축 및 환경 설정	2025-05-26 ~ 2025-05-30	서버, DB, 스토리지, 보안환경 구성
3단계	개발 및 기능 구현	2025-05-26 ~ 2025-05-20	회원가입, 로그인, 음원재생/다운로드 개발
4단계	보안 시나리오 설계 및 공격 실습	2025-05-21 ~ 2025-05-23	SQLi, XSS, 인증 우회 등 공격 테스트
5단계	보안 방어 체계 설계 및 검증	2025-05-30 ~ 2025-06-10	WAF, IDS/IPS, 로그 분석 연동 및 대응 체계 구축
6단계	최종 테스트 및 보고서 작성	2025-06-09 ~ 2025-06-10	시스템 통합 테스트 및 문서화 작업
7단계	발표 및 결과 공유	2025-06-11 ~ 2025-06-11	최종 보고서 제출 및 발표

전체 추진 일정

[illegible]

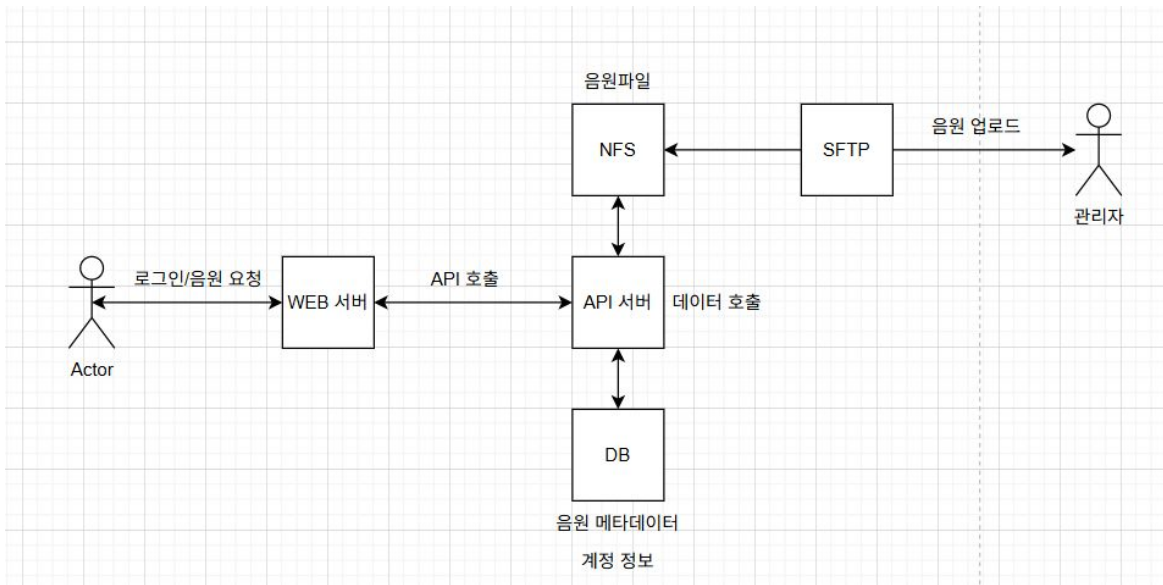
II 아키텍처 설계



1

시스템 구성도

- 사용자가 웹을 통해 음악을 **Streaming** 하고, 선택적으로 음원을 **Presigned URL**을 통한 안전한 방식으로 다운로드 할 수 있는 음악 플랫폼을 구축
- 운영자는 외부와 서버 간의 통신을 **SFTP**를 통해 음원 및 서버 관련 업데이트, 에러 사항을 수정하고 관련 파일을 안전하게 서버에 업로드 및 관리 할 수 있도록 구축
- 로그 수집 및 공격 시나리오 분석 기능을 통해 보안성 확보 및 향후 사용자 기반 추천 기능 등을 고도화를 고려한 확장 가능한 설계



2

주요 컴포넌트 설명

웹서버

회원가입 / 로그인 (세션 기반 인증)
음악 검색 (Flask API 연동)
음악 스트리밍 및 다운로드

방화벽

각 센터간 IPsec 통신
망 사이의 접근 제어

splunk

SIEM 활용하여 대시보드 작성
로그 관리 및 분석

3

기술 스택

네트워크 솔루션	Pfsense IPSec VPN
운영체제	Rocky Linux 9.3 ubuntu 22.04
보안 도구	알약 ModSecurity IPS(snort) GVM Security Onion
보안 테스트 OS	Kali linux
로그 분석	Splunk
프론트엔드	HTML CSS JS
백엔드	Flask MariaDB

4

설계 원칙

보안성

- WAF, IPS 를 활용하여 실시간 위협 탐지 및 차단
- 시스템 **command** 로깅

유지보수

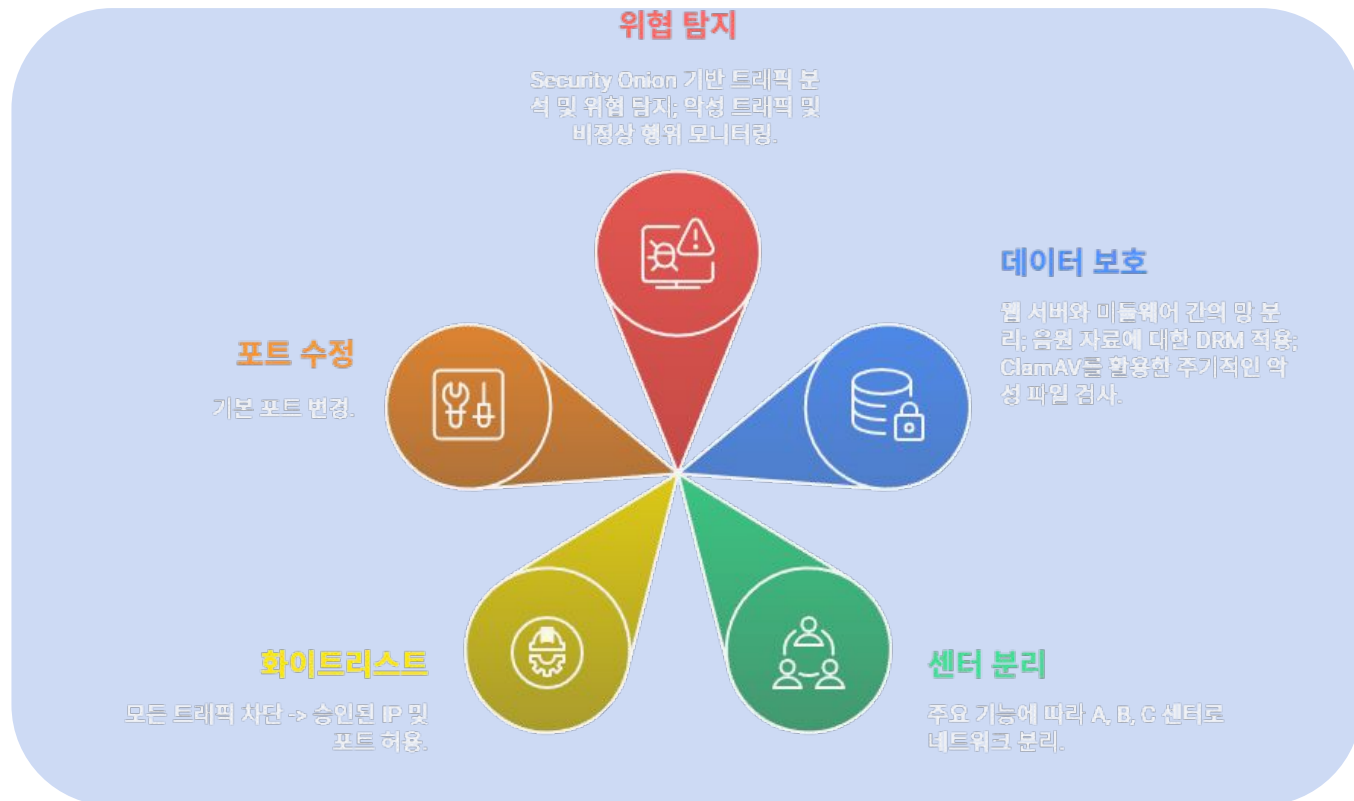
- 네트워크의 논리적/물리적 분리
- 방화벽 정책 최신화

최소 자원
할당

- 불필요한 낭비 감소
- 자원 할당량 문서화

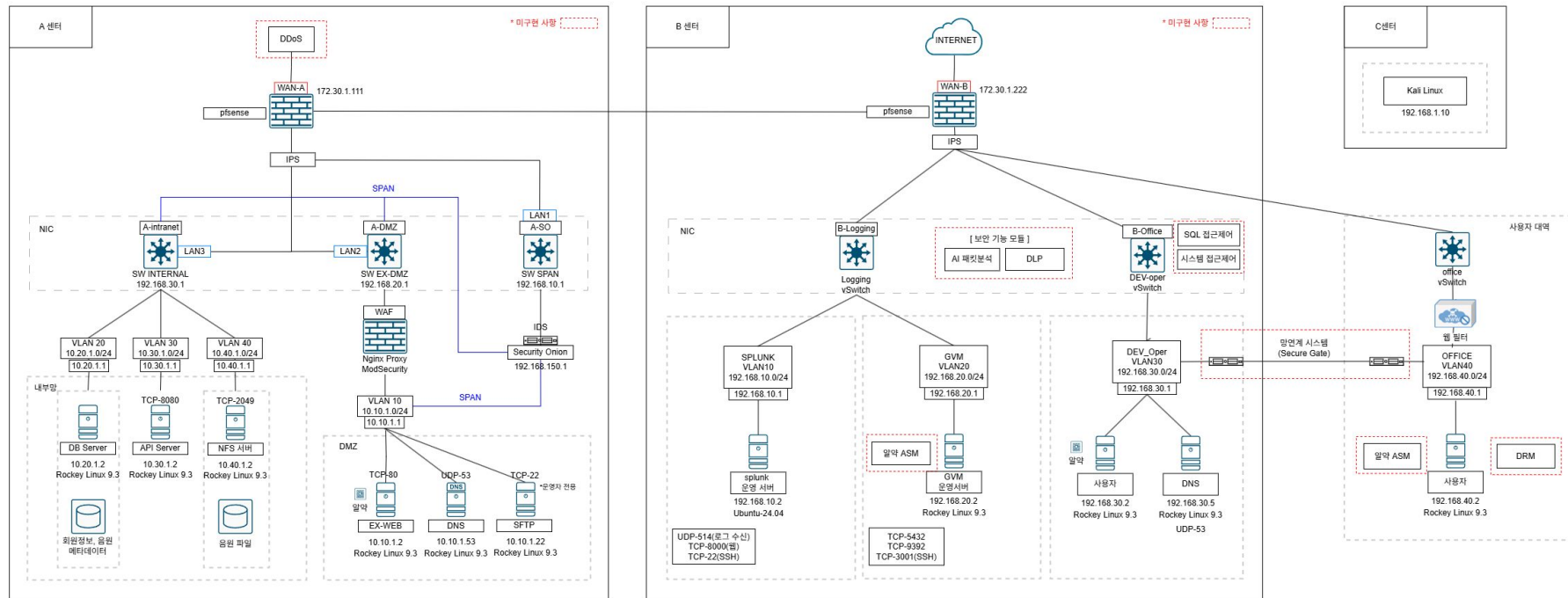
5

보안 설계 정의



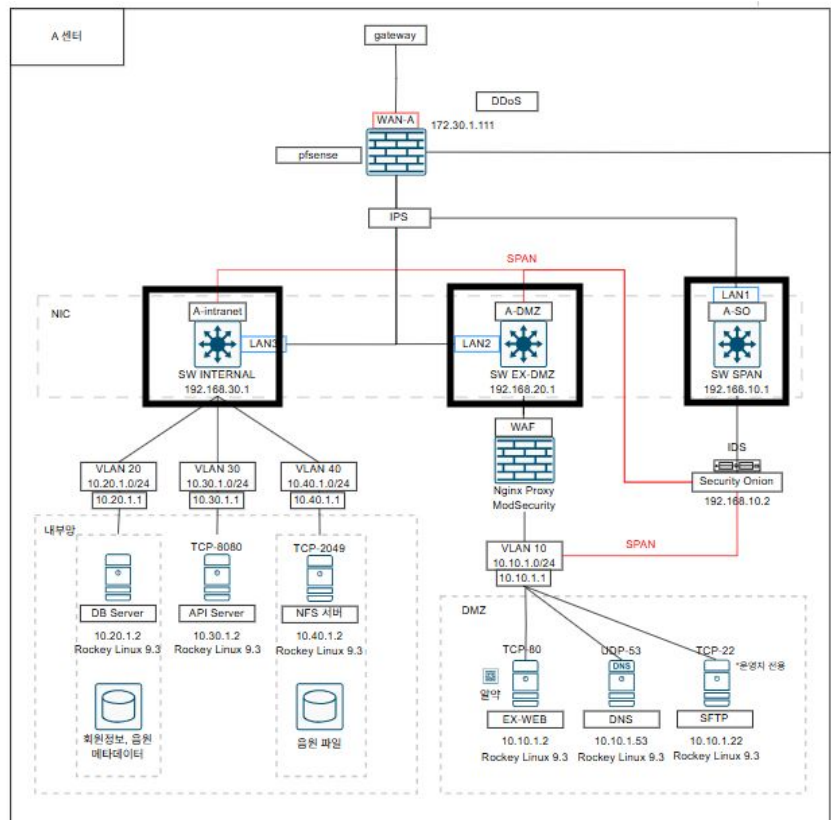
6

전체 아키텍처 구성도



6

A센터 아키텍처 구성도



메인 서비스 운영 센터

WEB/WAS/DB 서버

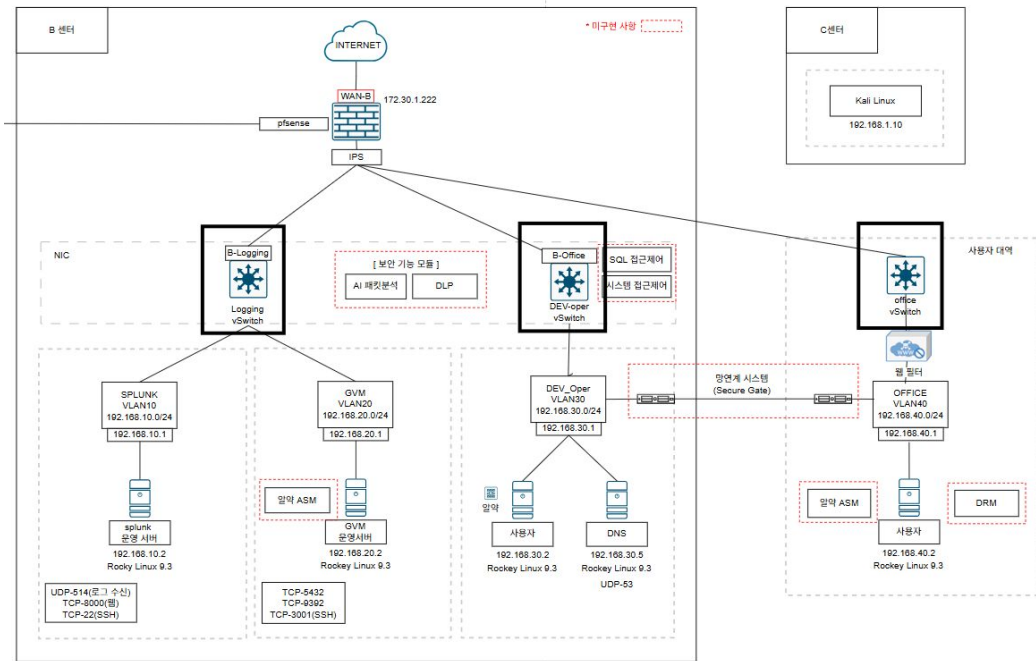
1. 주요 웹 서비스를 제공하기 위한 필수 구성 요소
2. 각 서버가 역할별로 분리되어 성능과 보안을 강화

3개의 물리적 NIC로 구성

1. Intranet(내부 네트워크)
 - 내부 사용자만 접근 가능
 - 인터넷 연결 없이 안정성 보장
 - 데이터 유출 위험 최소화
2. DMZ
 - 외부 사용자나 클라이언트 접근 가능
 - 내부 네트워크와 격리되어 위협 차단
3. SO(Security Onion)
 - 보안 모니터링 및 트래픽 분석
 - SPAN되어 물리는 현상 방지

6

B센터 아키텍처 구성도



로그 관리 센터

로그 관리

1. 로그 수집 및 취약점 관리
2. 외부 사용자 접속 제어

3개의 물리적 NIC로 구성

1. Logging
 - a. 로그와 보안 데이터를 안전하게 저장
 - b. 네트워크를 모니터링하여 위협 탐지
2. Dev-oper(Admin)
 - 모든 네트워크를 제어하는 중앙 관리
 - A센터의 모든 자원 접근 가능
 - 외부 네트워크와 연결되는 유일한 통로
3. Office
 - 외부 사용자는 Dev-oper를 통해 내부 접근 가능
 - 외부 접속의 안전성 제공

III 시스템 구축



1 OS 및 환경 구축

☐	가상 시스템 ▾	실행 상태 ▾	사용된 공간 ▾	게스트 운영 체제 ▾	호스트 이름 ▾	호스트 CPU...	호스트 메모리
☐	 C-KaliAttack_User1	 주의	52.08 GB	Debian GNU/Lin...	kali	160 MHz	2.05 GB
☐	 C-KaliAttack_User2	 정상	50.01 GB	Debian GNU/Lin...	알 수 없음	0 MHz	0 MB
☐	 A-UTM	 정상	39.1 GB	기타 Linux(64비트)	알 수 없음	252 MHz	4.02 GB
☐	 B-UTM	 정상	34.08 GB	기타 Linux(64비트)	알 수 없음	189 MHz	3.97 GB
☐	 A-WAF	 정상	29.92 GB	Ubuntu Linux(64...	알 수 없음	0 MHz	0 MB
☐	 A-WEB	 정상	18.37 GB	CentOS 9(64비트)	localhost.locald...	674 MHz	1.98 GB
☐	 A-SFTP_RokcyLinux93	 정상	50 GB	CentOS 9(64비트)	알 수 없음	0 MHz	0 MB
☐	 A-DB	 정상	6.37 GB	Red Hat Enterpr...	알 수 없음	49 MHz	1.06 GB
☐	 A-NFS	 정상	7.89 GB	Red Hat Enterpr...	알 수 없음	50 MHz	872 MB
☐	 A-API	 정상	8.94 GB	Red Hat Enterpr...	알 수 없음	67 MHz	862 MB
☐	 A-DNS	 정상	22.03 GB	Red Hat Enterpr...	알 수 없음	0 MHz	0 MB
☐	 B-AdminMgmt_Rocky	 정상	52.62 GB	CentOS 9(64비트)	알 수 없음	0 MHz	0 MB
☐	 B-splunk	 정상	27.54 GB	CentOS 9(64비트)	알 수 없음	353 MHz	1.96 GB
☐	 B-DNS	 정상	20 GB	CentOS 9(64비트)	알 수 없음	0 MHz	0 MB
☐	 Repo-Rocky	 정상	100 GB	CentOS 9(64비트)	알 수 없음	0 MHz	0 MB
☐	 B-ExternalAdminMamt...	 정상	40 GB	CentOS 9(64비트)	알 수 없음	0 MHz	0 MB
☐	 A-SecurityOnion	 정상	180 GB	기타 Linux(64비트)	알 수 없음	0 MHz	0 MB
☐	 B-GVM	 정상	80 GB	Ubuntu Linux(64...	알 수 없음	0 MHz	0 MB

1 OS 및 환경 구축 환경설명 (A 대역)

서비스명	운영체제	IP	디스크 할당 및 권한관리
pfsense	기타 Linux	172.30.1.111	
DB Server	Rocky Linux9.3	10.20.1.2	20GB(/root 2GB, /usr 4GB, /var 4GB, /data 4GB, /opt 2GB, /home 2GB, /tmp 2GB)
API Server	Rocky Linux9.3	10.30.1.2	20GB(/root 2GB, /usr 4GB, /var 4GB, /data 4GB, /opt 2GB, /home 2GB, /tmp 2GB)
NFS Server	Rocky Linux9.3	10.40.1.2	20GB(/root 2GB, /usr 4GB, /var 4GB, /data 4GB, /opt 2GB, /home 2GB, /tmp 2GB)
WAF	Ubuntu24.02	10.10.1.4	
Security Onion	기타 Linux	192.168.150.1	
EX-WEB	Rocky Linux9.3	10.10.1.2	30GB(/root 2GB, /usr 6GB, /var 6GB, /data 6GB, /opt 3GB, /home 4GB, /tmp 3GB)
DNS	Rocky Linux9.3	10.10.1.53	
SFTP	Rocky Linux9.3	10.10.1.22	50GB(/root 2GB, /usr 8GB, /var 6GB, /data 18GB, /opt 2GB, /home 6GB, /tmp 2GB)

1

SFTP 서버 환경설명 (A 대역)

디스크 공간은 총 50GB로 할당하였으며, 각 디렉터리별로 용도를 고려해 다음과 같이 분배했습니다.

/root (2GB): 시스템 관리자 계정의 홈 디렉터리로, 중요한 설정 파일과 스크립트가 위치하기 때문에 적절한 공간을 배정했습니다.

/usr (8GB): 시스템과 응용 프로그램 실행에 필요한 바이너리와 라이브러리들이 위치하는 곳으로, 충분한 공간 확보가 필요합니다.

/var (6GB): 로그 파일과 임시 데이터가 집중되는 디렉터리로, 로그가 과도하게 쌓여 시스템 운영에 문제를 일으키는 상황을 대비해 넉넉하게 공간을 배정했습니다.

/data (18GB): 서비스에서 다루는 음원 데이터나 사용자 콘텐츠가 저장되는 주요 데이터 공간으로 가장 큰 비중을 두었습니다.

/opt (2GB): 별도로 설치되는 추가 소프트웨어가 위치하는 곳으로, OpenSSH 서버가 기본 설치되어 있어 큰 공간이 필요하지 않다고 판단하여 최소 할당했습니다.

/home (6GB): 일반 사용자 홈 디렉터리로, 사용자별 데이터와 환경 설정을 위한 공간입니다.

/tmp (2GB): 임시 파일 저장 공간으로, 시스템과 응용 프로그램의 임시 데이터를 처리할 수 있도록 설정했습니다.

1 OS 및 환경 구축 환경설명 (B,C 센터, 사용자대역)

서비스명	운영체제	IP	디스크 할당 및 권한관리
pfsense	기타 Linux	172.30.1.222	
SPLUNK	Rocky Linux9.3	192.168.10.2	
GVM	Rocky Linux9.3	192.168.20.2	
관리자 PC(내부)	Rocky Linux9.3	192.168.30.2	50GB(/root 4GB, /usr 8GB, /var 8GB, /opt 4GB, /home 8GB, /tmp 4GB)
DNS	Rocky Linux9.3	192.168.30.5	
Kali	Debian11	192.168.1.10	50GB(/, 통합 관리) - /boot, swap을 제외한 대부분의 디렉터리가 / 루트 파티션 아래 통합 관리됨.
관리자 PC(외부)	Rocky Linux9.3	192.168.40.1	50GB(/root 4GB, /usr 8GB, /var 8GB, /opt 4GB, /home 8GB, /tmp 4GB)

1

관리자 서버 환경설명 (B 대역, 사용자대역)

내부/외부 관리자 PC는 내부 관리자 환경과 동일한 Rocky Linux 9.3 버전을 사용했으며, GUI 환경에서 효율적인 작업이 가능하도록 구성하였습니다.

디스크 공간은 총 50GB로 할당했으며, 내부 서버와 다소 차이를 둔 부분은 다음과 같습니다:

- **/root (4GB):** 관리자 홈 디렉터리 공간으로 내부와 동일하게 설정하여 안정적인 환경 유지
- **/usr (8GB):** 시스템과 응용 프로그램 실행에 필요한 주요 파일들이 위치하는 곳으로 충분한 공간 배분
- **/var (8GB):** 로그 및 임시 데이터 저장용으로 넉넉히 할당하여 작업 중 발생할 수 있는 데이터 누적에 대비
- **/opt (4GB):** 내부 서버 대비 2GB를 더 할당했는데, GUI 관련 패키지와 추가 소프트웨어 설치 공간 확보를 위해 확대함
- **/home (8GB):** 사용자 데이터 및 환경 설정 공간으로 내부와 동일하게 유지
- **/tmp (4GB):** 임시 파일 공간으로, GUI 작업 시 임시 데이터가 증가할 수 있어 더 넉넉히 배분

GUI 환경에서 다양한 관리 작업과 분석 업무가 원활히 진행될 수 있도록, 운영 환경 특성에 맞춰 디스크 공간을 세밀하게 조정하였습니다.

2

웹서비스 센터 구축 (웹서버 구축)

외부 사용자 접근을 위한 서비스 노출 필요. DMZ 영역에 위치시켜 보안 강화.

역할

- 사용자 요청(회원가입·로그인·음악 재생·다운로드) 수신 및 응답 반환
- 정적 리소스(HTML, CSS, JS) 제공
- API 서버로의 트래픽 전달

접속 권한

- 외부 클라이언트는 TCP 8443만 접근 가능.

보안 고려사항

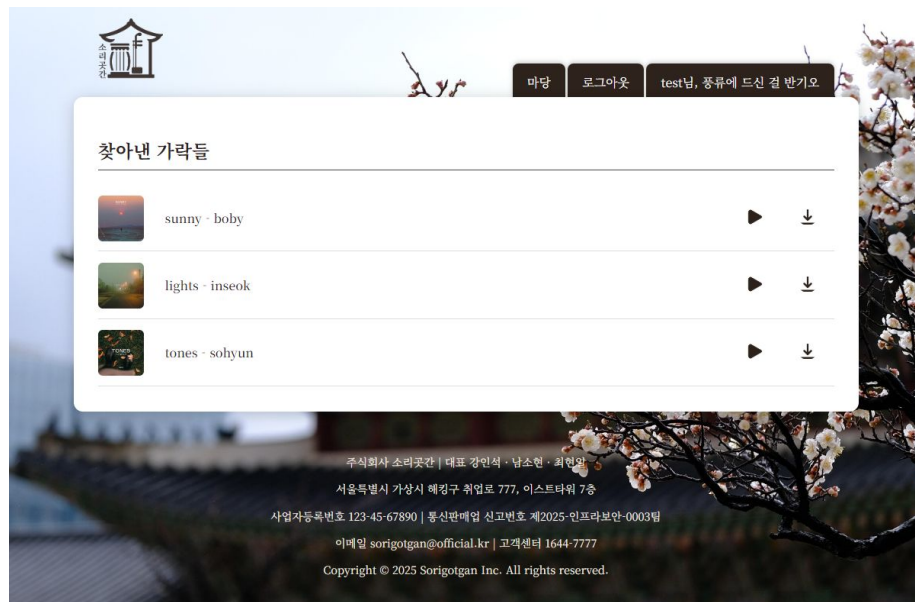
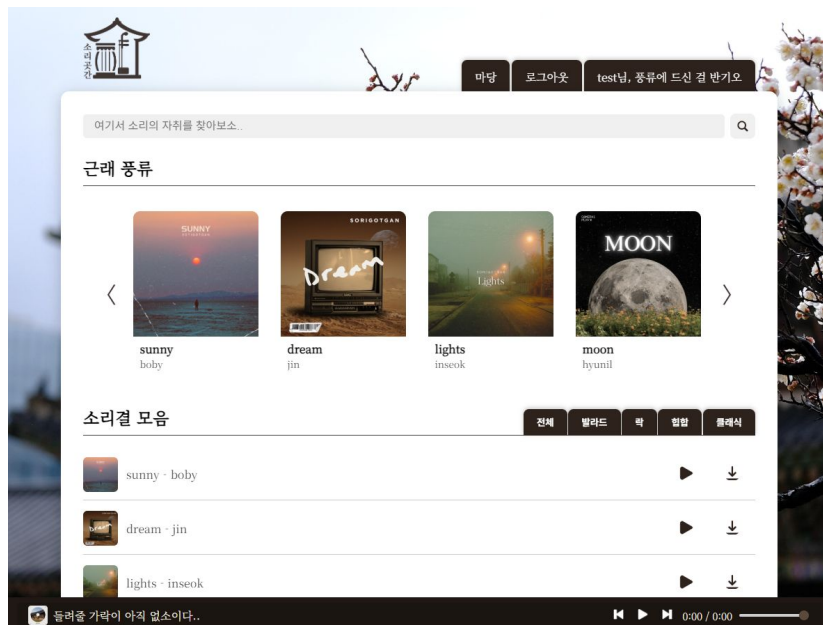
- WAF(ModSecurity) 선택재 및 프록시 통과 후 접속
- DMZ 분리 배치
- Splunk 및 Security Onion으로 SPAN 트래픽 모니터링

네트워크 구성

- 외부 포트: 80(HTTP), 443(HTTPS)
- 내부 통신:
 - API 서버 (TCP 5000)
 - DB 서버 (TCP 3306)
 - NFS 서버 (TCP 2049)

2 웹서비스 센터 구축 (웹서버 구축)

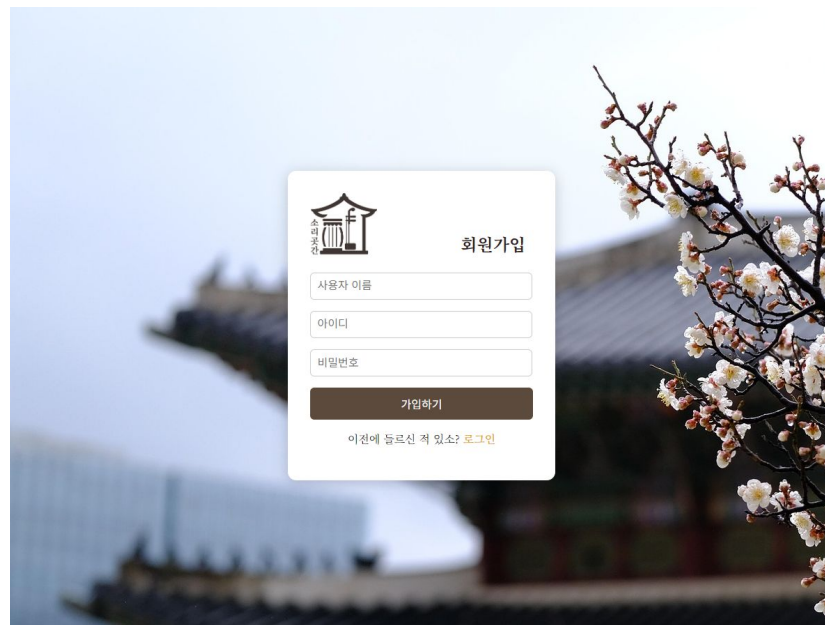
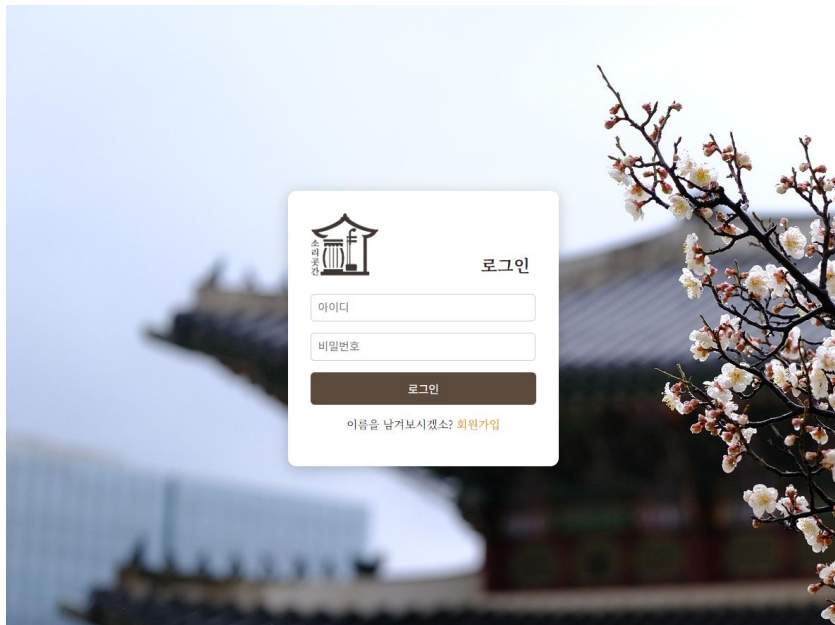
웹 사이트 구현 화면 - www.Sorigotgan.com



2

웹서비스 센터 구축 (웹서버 구축)

웹 사이트 구현 화면 - www.Sorigotgan.com



2

웹서비스 센터 구축 (웹서버 구축)

HTTP → HTTPS 자동 리디렉션 기능

```
package com.example.demo.config;

import org.apache.catalina.connector.Connector;
import org.springframework.boot.web.embedded.tomcat.TomcatServletWebServerFactory;
import org.springframework.boot.web.server.WebServerFactoryCustomizer;
import org.springframework.boot.web.servlet.server.ConfigurableServletWebServerFactory;
import org.springframework.context.annotation.Bean;
import org.springframework.context.annotation.Configuration;

@Configuration
public class HttpToHttpsRedirectConfig {

    @Bean
    public WebServerFactoryCustomizer<ConfigurableServletWebServerFactory> containerCustomizer() {
        return factory -> {
            if (factory instanceof TomcatServletWebServerFactory tomcatFactory) {
                tomcatFactory.addAdditionalTomcatConnectors(httpConnector());
            }
        };
    }

    private Connector httpConnector() {
        Connector connector = new Connector("org.apache.coyote.http11.Http11NioProtocol");
        connector.setScheme("http");
        connector.setPort(8080);
        connector.setSecure(false);
        connector.setRedirectPort(8443);
        return connector;
    }
}
```

HTTP 요청을 별도로 받아들이면서도 최종적으로는 HTTPS로만 서비스하기 위해 구현

사용자가 **http://...:8080** 으로 접속하더라도 자동으로 **https://...:8443** 로 전환하게끔 지원

보안 강화

- 사용자가 HTTP로 접속하더라도 전송 구간 암호화가 보장
- 중간자 공격(MITM) 및 패킷 도청 위험 감소
- SEO 측면에서도 '안전한 사이트'로 인식되어 점수 상승 가능

2

웹서비스 센터 구축 (웹서버 구축)

클라이언트 요청을 내부 API 서버로 프록시 기능

```

@RestController
public class ProxyController {

    @Value("${proxy.api.base-url}")
    private String apiBaseUrl;

    private final RestTemplate restTemplate = new RestTemplate();

    @GetMapping("/api/search")
    public ResponseEntity<String> proxySearch(@RequestParam("keyword") String keyword, HttpServletRequest request) {
        String targetUrl = apiBaseUrl + "/search?keyword=" + keyword;
        return restTemplate.exchange(targetUrl, HttpMethod.GET, null, String.class);
    }

    @PostMapping("/api/login")
    public ResponseEntity<String> proxyLogin(@RequestBody String body) {
        String targetUrl = apiBaseUrl + "/login";
        HttpHeaders headers = new HttpHeaders();
        headers.setContentType(MediaType.APPLICATION_JSON);
        HttpEntity<String> entity = new HttpEntity<>(body, headers);
        return restTemplate.exchange(targetUrl, HttpMethod.POST, entity, String.class);
    }

    @PostMapping("/api/register")
    public ResponseEntity<String> proxyRegister(@RequestBody String body) {
        String targetUrl = apiBaseUrl + "/register";
        HttpHeaders headers = new HttpHeaders();
        headers.setContentType(MediaType.APPLICATION_JSON);
        HttpEntity<String> entity = new HttpEntity<>(body, headers);
        return restTemplate.exchange(targetUrl, HttpMethod.POST, entity, String.class);
    }

    @GetMapping("/api/stream/**")
    public ResponseEntity<byte[]> proxyStream(HttpServletRequest request) {
        // subpath 추출
        String fullUri = request.getRequestURI(); // 예: /api/stream/music/song1.mp3
        String subpath = fullUri.replaceFirst("/api/stream/", "");
    }

```

프록시 컨트롤러를 통해 클라이언트와 백엔드 API 사이에 게이트웨이 역할을 구현

보안 강화

- **CORS 이슈 해소:** 프론트엔드가 직접 다른 도메인의 API를 호출할 때 발생하는 교차 출처 제약 우회
- **내부 주소 은닉:** 클라이언트에 실제 `apiBaseUrl`을 노출하지 않고, `/api/**` 경로만 호출하도록 통일
- **공통 처리 일원화:** 인증 헤더 삽입, 로깅, 예외·타임아웃 설정 등을 한 곳에서 관리

2

웹서비스 센터 구축 (API서버 구축)

주요 역할:

- Flask 기반 RESTful API 제공
- 웹 서버로부터 들어오는 비즈니스 로직 처리
- DB(MariaDB) 및 NFS 연동을 통한 데이터 CRUD

접속 권한:

- 웹 서버 (EX-WEB): TCP 5000 포트로만 접근 허용
- 내부 관리자: SSH(10.10.1.3:22) 또는 SFTP를 통한 유지보수
- 외부 클라이언트: 직접 접근 불가 (웹 서버 프록시 경유)

보안 고려사항:

1. 논리적 네트워크 분리
 - 내부망 (애플리케이션 존)에 배치, DMZ와 별도 구역
2. 입력 검증 및 공격 방어
 - SQL Injection, CSRF, XSS 방어 로직 필수
 - rate limiting 및 IP 화이트리스트/블랙리스트
3. 모니터링 & 로깅
 - Splunk와 Security Onion으로 트래픽·이벤트 수집
 - 이상 트래픽 탐지 시 알림 설정
4. 포트 관리
 - TCP 5000, SSH(22) 외 불필요한 포트 차단
5. 취약점 점검
 - 정기적인 Dependency 검사 및 보안 패치 적용

2

웹서비스 센터 구축 (API서버 구축)

API 보안 강화 포인트

```
# 로그인 API
@app.route('/login', methods=['POST'])
def login():
    data = request.get_json()
    username = data.get('username')
    password = data.get('password')

    try:
        conn = pymysql.connect(
            host=DB_HOST,
            user=DB_USER,
            password=DB_PASS,
            db=DB_NAME,
            charset='utf8mb4',
            cursorclass=pymysql.cursors.DictCursor
        )
        with conn.cursor() as cursor:
            sql = "SELECT * FROM users WHERE username = %s"
            cursor.execute(sql, (username,))
            user = cursor.fetchone()

            if not user:
                return jsonify({"success": False, "message": "존재하지 않는 사용자입니다."}), 401

            hashed_pw = user['password'].encode('utf-8')
            if bcrypt.checkpw(password.encode('utf-8'), hashed_pw):
                return jsonify({"success": True})
            else:
                return jsonify({"success": False, "message": "비밀번호가 일치하지 않습니다."}), 401
    except Exception as e:
        print("! Login Error:", e)
        return jsonify({"success": False, "message": str(e)}), 500
    finally:
        conn.close()
```

1. SQL 인젝션 방지

- 파라미터 바인딩 (%s) 사용
- 사용자 입력을 쿼리와 분리하여 SQL 삽입 차단

2. 비밀번호 암호화 적용 (bcrypt)

- 단방향 해시 + 솔트 적용, `bcrypt.checkpw()`로 안전한 검증
- 평문 비밀번호 노출 위험 없음

3. 예외 처리 및 리소스 보호

- `try-except-finally` 구조
- DB 연결 오류 및 예외 처리
- `conn.close()`로 자원 누수 방지
- DoS 공격 완화

2

웹서비스 센터 구축 (DB서버 구축)

역할

- 사용자 정보·음악 메타데이터 저장 및 관리
- 검색 API 및 웹 서버의 데이터 요청 처리

구성 방식

- MariaDB 사용
- 비밀번호·개인정보 일방향 암호화(해시)

네트워크 구성

- 내부망 전용 통신
- 포트: 3306

회원정보				users
아이디	user_id	Domain	INT	
사용자 이름	username	Domain	VARCHAR(50)	
비밀번호	password	Domain	VARCHAR(255)	
가입일	created_at	Domain	DATETIME	

음원 메타데이터				music
음원 ID	music_id	Domain	INT	
음원 제목	title	Domain	VARCHAR(100)	
아티스트 이름	artist	Domain	VARCHAR(100)	
앨범명	album	Domain	VARCHAR(100)	
장르	genre	Domain	VARCHAR(100)	
NFS에서 마운트된 로컬 경로	file_path	Domain	VARCHAR(255)	

3

관리자 센터 구축

SPLUNK SERVER(B-splunk)

역할

1. 중앙화된 로그 수집 및 관리

- 다양한 장비에서 생성되는 로그를 중앙 서버에서 통합적으로 수집
- 로그의 검색, 필터링, 저장 기능 제공으로 로그 관리 효율성 향상

2. 실시간 데이터 분석 및 모니터링

- 실시간 로그 분석을 통해 이상 징후 및 보안 이벤트 탐지
- 대시보드 및 알림 기능으로 빠른 대응 가능

보안

1. Forwarder 와 index 간 VPN 통신

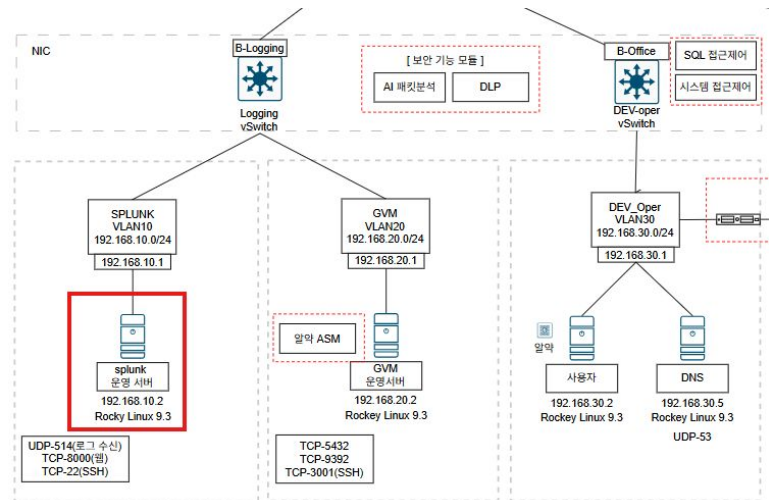
- 데이터를 암호화하여 안전한 로그 전달

2. Splunk Web 접근 제한

- 논리적으로 분리된 Admin 네트워크에서만 접근
- 불필요한 접근 차단

3. OS 방화벽 설정

- 데이터 전송 포트 개방(TCP/9997, UDP/514)



3 관리자 센터 구축

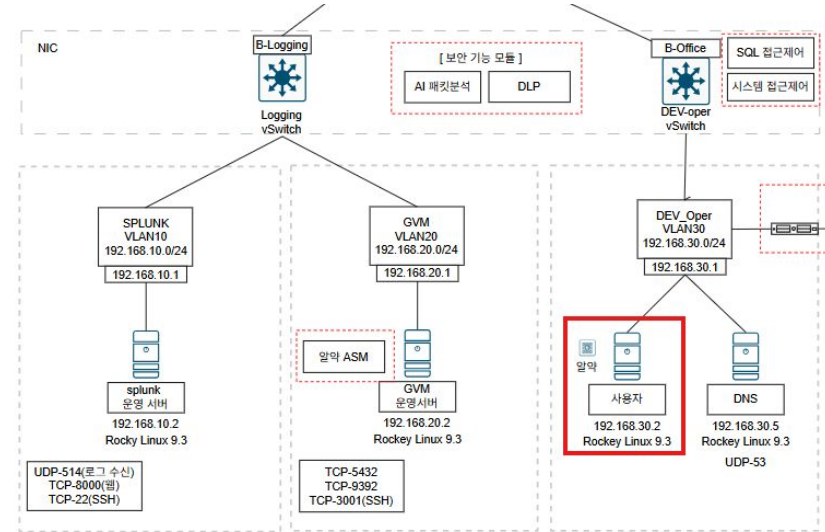
Admin 서버(B-AdminMgmt_Rocky)

역할

- A 센터 자원의 관리 허브
 - 논리적으로 분리된 A 센터 내부 자원에 접근하고 관리하는 전용 서버
- 보안 및 접근 제어
 - 외부 사무실 사용자의 A 센터 자원 접근을 중계

보안

- 논리적 네트워크 분리
 - VPN 통신 -> 암호화 통신으로 데이터 보호
 - 외부 인터넷 차단 - 외부 통신 모두 차단
- 최소 권한 원칙
 - 모든 자원에 접근하는 최고 권한 보유
 - 최소한의 포트 개방



IV 보안 시스템 고도화



1

WAF 및 방화벽 적용

ModSecurity + OWASP CRS

- 오픈소스 웹 방화벽
- 웹 애플리케이션의 취약점으로부터 보호
- OWASP CRS 를 규칙으로 추가하여 활성화
- JSON 형태로 저장된 LOG 예시 -> URI 확인 가능

```
{ [-]
  transaction: { [-]
    client_ip: 127.0.0.1
    client_port: 40202
    host_ip: 127.0.0.1
    host_port: 80
    messages: [ [+]
```

```
]
  producer: { [+]
```

```
}
  request: { [-]
    headers: { [+]
```

```
}
    http_version: 1.1
    method: GET
    uri: /?testparam=test
```

```
}
  response: { [+]
```

```
}
  server_id: 65948cc669e35ee13c983dca0d9b77b6bd0aa3e
  time_stamp: Sun Jun 8 14:49:49 2025
  unique_id: 174939418940.410331
}
```

pfSense

- 방화벽 정책 설정

		0/0 B	IPv4 TCP	A_VLAN30_API subnets	*	10.20.1.2	*	*	none	
		0/0 B	IPv4 TCP/UDP	A_VLAN30_API subnets	*	10.40.1.2	*	*	none	VLAN30 API <=> VLAN40 FILE NFS allow
		0/0 B	IPv4+6*	*	*	A_VLAN30_API subnets	*	*	none	Block: any->VLAN30_API
		0/0 B	IPv4+6*	A_VLAN30_API subnets	*	*	*	*	none	Block: VLAN30_API->any

3

Splunk 대시보드 구성



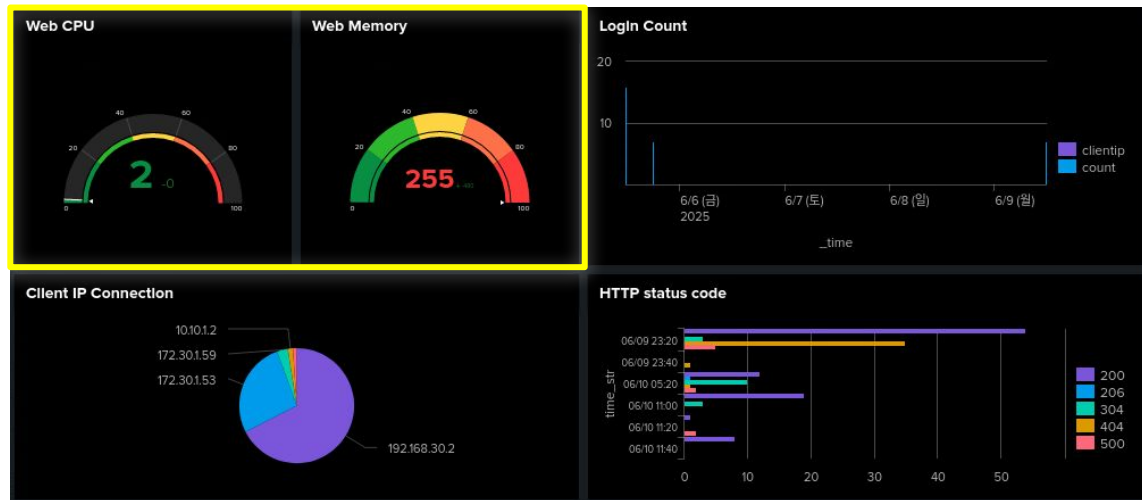
3

Splunk 대시보드 구성 설명

구성 항목	설명	보안 위협 대응 목적
Root 로그인 상태 확인	시스템별 관리자 사용자 로그인 시도 현황, 성공/실패 비율 시각화	Brute Force 공격, 내부 사용자 계정 도용 시도 등 인증 관련 이상 징후를 조기 탐지
웹서버 이상징후 로그	HTTP 응답 코드(5xx/4xx), 트래픽 급증, User-Agent 이상 값 필터링	웹шел 업로드 시도, 디렉토리 트래버설, SQLi 등 웹 기반 공격 탐지
Syslog 기반 Error/Warning 로그	시스템 로그에서 Error, Warning 키워드 필터링	시스템 불안정 상태, 설정 오류, 비인가 접근 등 보안 사고 징조 사전 인지
SFTP 서버 경고 이벤트	인증 실패, 권한 오류, 경로 접근 실패 이벤트 등 시각화	외부 SFTP 접근 시도, 잘못된 접근 경로 시도 등 비인가 침입 감지
API 서버 BruteForce 탐지	동일 IP/계정으로 다중 실패 시도 분석 (로그인 실패 횟수/간격 기반)	자동화된 무차별 대입 공격 탐지 및 방어 정책 수립 기반 데이터 제공

3

Splunk 대시보드 구성

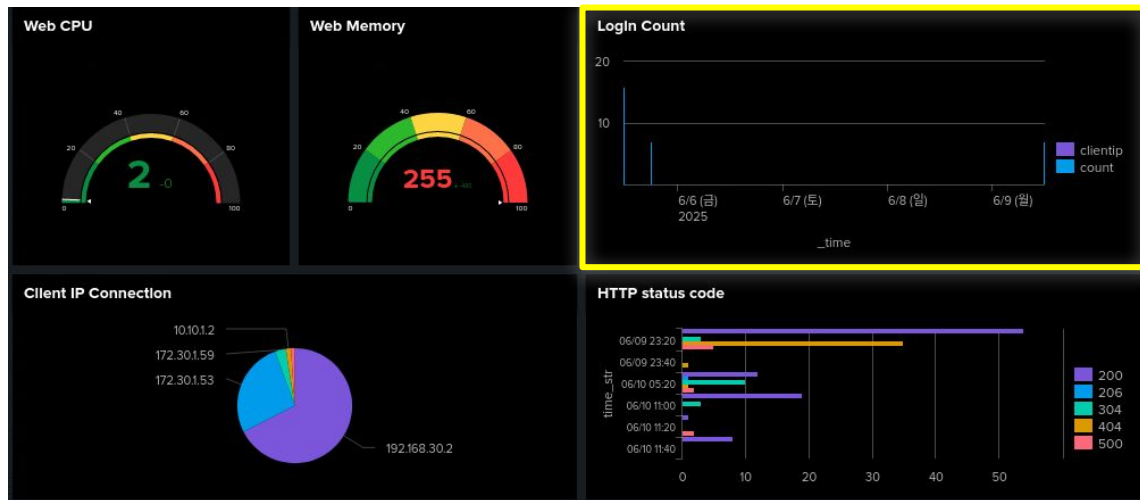


웹서버 상태 체크



3

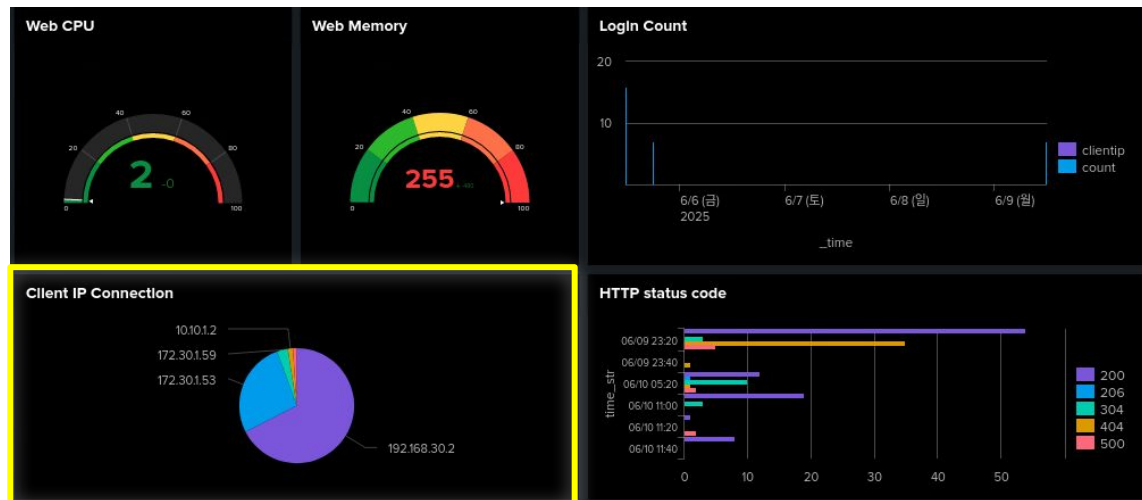
Splunk 대시보드 구성



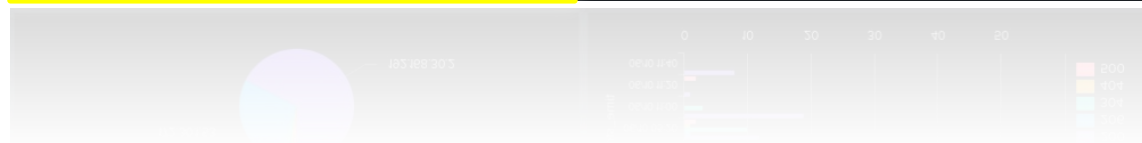
시간대별 로그인 추이

3

Splunk 대시보드 구성

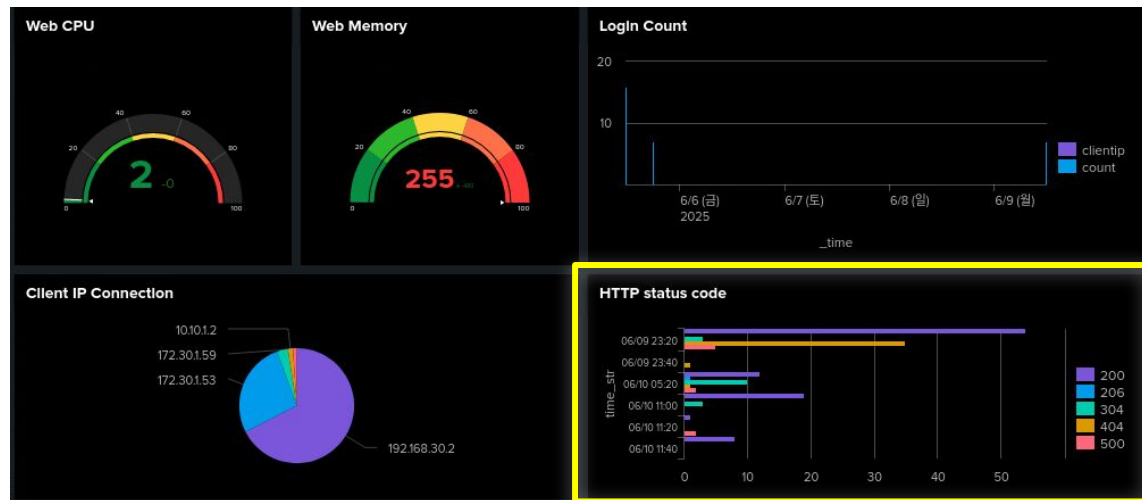


접속된 IP 분포 파악



3

Splunk 대시보드 구성



응답 코드 분석을 통한
서비스 이상 탐지

200: 정상

404: 잘못된 경로 접근

500: 내부 서버 오류

3

Splunk 대시보드 구성

URL Request		
uri_path	count	
/login	2209	
	400	505
/api/stream/music/song1.mp3	382	
/api/search?keyword=	374	
/login?username=brute&password=16165	137	
/api?username=brute&password=16165	137	
<이전 1 2 3 4 5 ... 다음>		

XSS		
_time	host	xss_payload
2025-06-09T14:22:47.000+09:00	10.10.1.2	%3Cscript%3E%20alert(%27hello%27)%20%3C%2Fscript%3E
2025-06-09T14:22:46.000+09:00	10.10.1.2	%3Cscript%3E%20alert(%27hello%27)%20%3C%2Fscript%3E
2025-06-09T14:22:47.000+09:00	10.30.1.2	<script>%20alert('hello')%20
<이전 1 2 3 다음>		

SQL Injection		
i	시간	이벤트
>	6/9/2025 11:45:46.000 AM	<pre>{ "_time": "2025-06-09T11:45:46.000+09:00", "host": "10.30.1.2", "username": " OR 1=1 -- , PW: 1234", "password": null }</pre>
원시 텍스트로 표시		



URL 요청 순위

3

Splunk 대시보드 구성

URL Request		
uri_path	count	
/login	2209	
	400	505
/api/stream/music/song1.mp3	382	
/api/search?keyword=	374	
/login?username=brute&password=16165	137	
/api?username=brute&password=16165	127	
<이전 1 2 3 4 5 ... 다음>		

XSS		
_time	host	xss_payload
2025-06-09T14:22:47.000+09:00	10.10.1.2	%3Cscript%3E%20alert(%27hello%27)%20%3C%2Fscript%3E
2025-06-09T14:22:46.000+09:00	10.10.1.2	%3Cscript%3E%20alert(%27hello%27)%20%3C%2Fscript%3E
2025-06-09T14:22:47.000+09:00	10.30.1.2	<script>%20alert('hello')%20
<이전 1 2 3 다음>		

i	시간	이벤트
>	6/9/2025 11:45:46.000 AM	<pre>{ "_time": "2025-06-09T11:45:46.000+09:00", "host": "10.30.1.2", "username": "OR 1=1 --", "password": null }</pre>
원시 텍스트로 표시		

XSS 탐지 로그

3

Splunk 대시보드 구성

URL Request		XSS	
uri_path	count	_time	host
/login	2209	2025-06-09T14:22:47.000+09:00	10.10.1.2
/api/stream/music/song1.mp3	400	2025-06-09T14:22:46.000+09:00	10.10.1.2
/api/search?keyword=	505	2025-06-09T14:22:46.000+09:00	10.10.1.2
/api/search?keyword=	382	2025-06-09T14:22:46.000+09:00	10.10.1.2
/login?username=brute&password=16165	374	2025-06-09T14:22:46.000+09:00	10.10.1.2
/login?username=brute&password=16165	137	2025-06-09T14:22:47.000+09:00	10.30.1.2
/login?username=brute&password=16165	137	2025-06-09T14:22:47.000+09:00	10.30.1.2
<이전 1 2 3 4 5 ... 다음>		<이전 1 2 3 다음>	

SQL Injection	
i	이벤트
>	6/9/2025 11:45:46.000 AM { _time: "2025-06-09T11:45:46.000+09:00", host: "10.30.1.2", username: " OR 1=1 -- , PW: 1234 sql: {"SELECT * FROM users WHERE username = ", password: null }
	원시 텍스트로 표시



SQL Injection 탐지 상세로그

V 검증 결과 및 로그 분석



1

공격 시나리오 설정

“ 구현된 기능을 바탕으로, 개발자와 보안 진단자의 관점에서 총 25개의 공격 시나리오를 설계 ”

1	공격 대분류	테스트 툴	공격 중분류	공격 소분류	공격 기법	대응 방법
2	응용 프로그램		Injection	SQL 인젝션	admin' OR '1'='1 입력	PreparedStatement 사용, 입력값 검증
3	응용 프로그램		Injection	XSS	<script>alert("XSS")</script> 삽입	출력 시 HTML Escape 처리, CSP 적용 <> 를 다른 문자로 대체
4	응용 프로그램		정보 노출	에러 메시지 출력	500, DB 오류 노출	공용 에러 페이지 설정, 상세 로그는 서버에만
5	응용 프로그램		정보 노출	디렉터리 리스팅	경로 진입 시 index.html 없음	서버에서 디렉터리 인덱싱 비활성화
6	응용 프로그램		정보 노출	음원 구조 추측	/music/1.mp3 등 직접 입력	URL 무작위화 또는 접근 권한 분리
7	응용 프로그램		정보 노출	중간자 공격	username/password 평문 노출	HTTPS 공인 인증서 적용
8	응용 프로그램		인증 우회	localStorage 위조	브라우저에서 세션 값 수정	서버 측에서 세션 검증 필수
9	응용 프로그램	postman	인증 우회	토큰 없이 API 호출	인증 헤더 없이 요청	API 접근 시 사용자 인증 확인
10	응용 프로그램		인가 우회	타인 음원 다운로드	curl로 파일 직접 다운로드	파일 요청 시 사용자-소유자 매칭
11	응용 프로그램		인가 우회	웹셀 업로드	악성 스크립트를 웹서버에서 직접 실행	업로드 파일 실행 디렉토리 분리
12	응용 프로그램		세션 관리 실패	세션 무기한 유지	localStorage에 남아있음	만료시간 설정, 로그인 시 세션 재발급
13	응용 프로그램		세션 관리 실패	세션 만료 미처리	로그인 유지 시간 무제한	세션 타임아웃 설정
14	응용 프로그램		자동화 공격	Brute-force 로그인	패스워드 반복 대입	Captcha 적용, 로그인 실패 제한
15	응용 프로그램		자동화 공격	Credential Stuffing	공개된 ID/PW 재사용	이상 로그인 탐지, MFA 도입
16	응용 프로그램		프로세스 검증 누락	다운로드 소유자 미검증	/download/<경로> 직접 접근	DB에서 사용자와 경로 매칭
17	응용 프로그램		파일 접근 제어 미비	디렉터리 트래버설	../.. 경로로 접근	경로 필터링, 화이트리스트만 허용
18	응용 프로그램		파일 접근 제어 미비	경로 직접 노출	file_path 그대로 출력됨	경로를 외부에 노출하지 않기
19	응용 프로그램		암호 정책 미흡	취약 비밀번호 허용	1234, password 등 설정 가능	강력한 패스워드 정책 설정
20	응용 프로그램		디렉터리 인덱싱	index.html 없음	경로 접근 시 파일 목록 노출	서버 설정으로 인덱싱 비활성화
21	응용 프로그램	개발자도구	JS 우회 재생	오디오 URL 추출	개발자도구로 src 확인	DRM 적용, referrer 검증
22	시스템/네트워크	nmap	포트 탐지	nmap	열린 포트 및 OS 스캔	불필요 포트 닫기, IDS/IPS 탐지 설정
23	네트워크	Burpsuite	중간자 공격	MITM	HTTP 통신 가로채기	HTTPS 적용, HSTS 설정
24	네트워크		Flooding	GET Flooding	파일 다운로드 대량 GET 요청	WAF 설정, connection timeout 제한
25	네트워크	파이어 스크립트	Flooding	DNS query flooding	특정 DNS 서버에 대량의 요청	출발지 IP 별 임계치 차단

공격 시도 및 탐지 결과

GET Flooding



공격자

1 공격자가 과도한 다운로드 요청

```
import requests
from concurrent.futures import ThreadPoolExecutor

url = "https://172.30.1.111:8443/api/stream/music/song1.mp3"

number_of_requests = 1000
threads = 50

def download_file():
    try:
        response = requests.get(url, verify=False, timeout=5)
    except:
        print('error')

def send_requests():
    with ThreadPoolExecutor(max_workers=threads) as executor:
        for _ in range(number_of_requests):
            executor.submit(download_file)

if __name__ == "__main__":
    send_requests()
    print("finished")
```

```
(root@user)~# curl -k https://172.30.1.11:8443/api/stream/music/song1.mp3 -output file
% Total % Received % Xferd Average Speed Time Time Current
ent
0 0 0 0 0 0 0 0 0 --:--:-- --:--:-- --:--:--
99 6456k 99 6427k 0 0 4574k 0 0:00:01 0:00:01 4571
100 6456k 100 6456k 0 0 4583k 0 0:00:01 0:00:01 4582
k

(root@user)~# ls
file # 1006115 1.0.0 Sublime Merge

(root@user)~# file file
file: Audio file with ID3 version 2.3.0, contains: MPEG ADTS, Layer III, v1,
320 kbps, 44.1 kHz, JntStereo
```

2025-06-09 07:17:14		0	TCP	172.30.1.90	59384	172.30.1.111	443	1:3000001	GET Flooding detected
------------------------	---	---	-----	-------------	-------	--------------	-----	-----------	-----------------------

GET Flooding(DoS 유형) 으로 탐지



sunny - boby



2

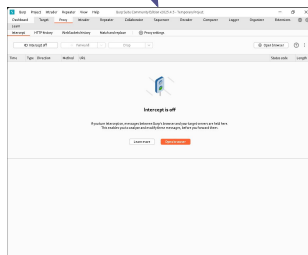
공격 시도 및 탐지 결과

중간자 공격

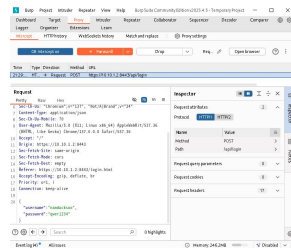


공격자

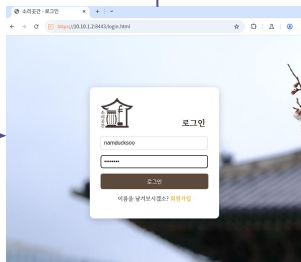
① 사용자를 내부 브라우저로 유도



② 로그인 시도



③ 사용자 정보 탈취



URL Request

url_path	count
/login	2192
/api/stream/music/song1.mp3	490
/api/search/keyword=	382
/login?username=brute&password=1q1w1e	354
/login?username=brute&password=1q1w1e	137

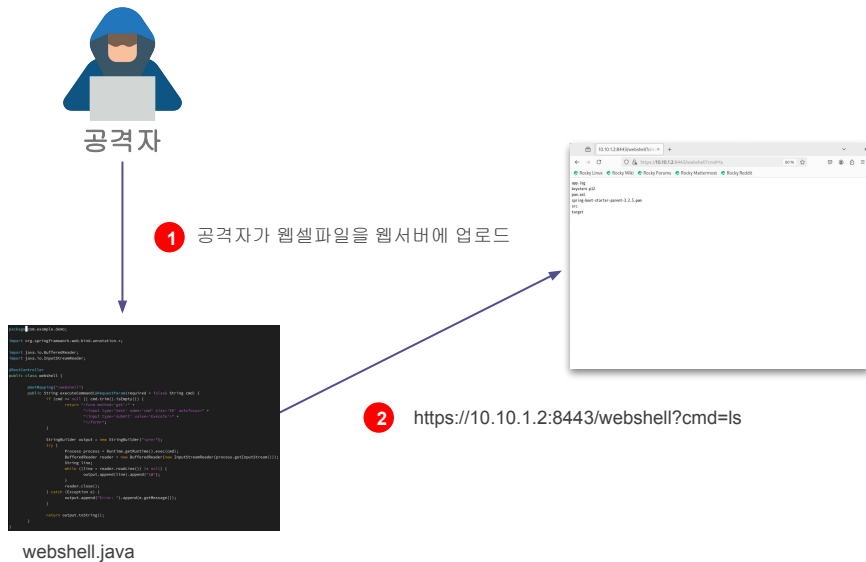
< 이전 1 2 3 4 5 ... 다음 >

Burp로 보내진 url 확인

2

공격 시도 및 탐지 결과

WebShell 공격



url_path	count
/login	2184
/api/search?keyword=	245
/login?username=brute&password=16165	137
/login?username=brute&password=64865	137
/login?username=brute&password=123484916	136

< 이전
1
2
3
4
5
...
다음 >

webshell이 들어간 URL을 확인 가능

2

공격 시도 및 탐지 결과

SQL Injection



```

> 25/06/09 11:54:42.000 10.10.1.2 - - [09/Jun/2025 11:54:42] "POST /login HTTP/1.1" 200 -
    host = 10.30.1.2 source = /root/api-server/flask_stdout.log sourcetype = flask:auto

> 25/06/09 11:54:42.000 login try -> ID: '1' OR 1=1 -- ', PW: '1234'
    host = 10.30.1.2 source = /root/api-server/flask_stdout.log sourcetype = flask:auto
  
```

API로 부터 수집된 로그인 로그

dashboardWEB

새로 시간 범위: 최근 24시간

Main: 400 21 09:00

2025-06-05T15:46:28.000+ 10.30.1.2 %3Cscript%3Ealert(1304);

SQL Injection

시간	이벤트
6/9/2025 10:45:46.000 AM	<pre> { "_type": "2025-06-05T11:45:46.000+09:00", "host": "10.30.1.2", "username": "1' OR 1=1 -- ", "password": "1234", "payload": "1' OR 1=1 -- ", "PW": "1234" } </pre> 원시 텍스트로 표시

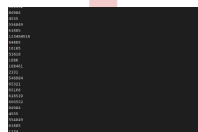
인젝션을 탐지한 대시보드 화면

2

공격 시도 및 탐지 결과

Brute-force & Credential Stuffing

① 패스워드 반복 대입 공격



```
[root@localhost ~]# hydra -l brute -P attackpassword.txt 10.10.1.2 https-get-for
m -u /login?username="USER"&password="PASS"&로그인 실패" -a 8443 -V
hydra 0.14.2 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use for
military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-09 14:13:
00
[WARNING] Restorefile (you have 10 seconds to abort... (use option -t to skip me
eting)) from a previous session found, to prevent overwriting, /hydra.restore
[DATA] max 50 tasks per 1 server, overall 10 tasks, 14321 login tries (l1/p:143
21), 4896 tries per task
[DATA] attacking https://10.10.1.2:8443/login?username="USER"&password=
"PASS"&로그인 실패
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "84916" - 1 of 14321 [child 0]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "64895" - 2 of 14321 [child 1]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "16165" - 3 of 14321 [child 2]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "168401" - 4 of 14321 [child 3]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "2131" - 5 of 14321 [child 4]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "546984" - 6 of 14321 [child 5]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "65321" - 7 of 14321 [child 6]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "65368" - 8 of 14321 [child 7]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "618519" - 9 of 14321 [child 8]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "666552" - 10 of 14321 [child 9]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "808984" - 11 of 14321 [child 10]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "84555" - 12 of 14321 [child 11]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "554849" - 13 of 14321 [child 12]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "61889" - 14 of 14321 [child 13]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "61889" - 15 of 14321 [child 14]
(S/R)
[ATTEMPT] target 10.10.1.2 - login "brute" - pass "61889" - 16 of 14321 [child 15]
(S/R)
```

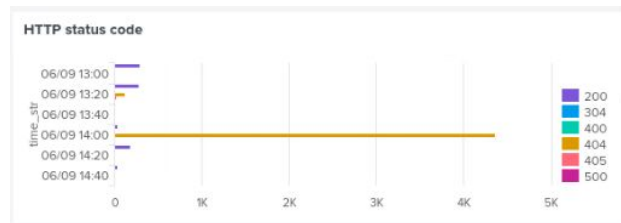
URL Request

password=123456789	136
/login?username=brute&password=84916	136
/login?username=brute&password=64895	136
/login?username=brute&password=16165	136
/login?username=brute&password=4555	136
/login?username=brute&password=61889	136

로그인 URL 요청 증가

URL Request

url_path	count
/login	2184
/login?search?keyword=	245
/login?username=brute&password=84916	137
/login?username=brute&password=64895	137
/login?username=brute&password=16165	136
password=123456789	136



404 로그인 실패 횟수 증가

"유출된 비밀번호 목록 또는 사전 파일을 활용한 자동화된 인증 시도는 탐지 로그상 동일한 양상"

3

한계점 및 대응 방안

한계점

- LocalStorage는 클라이언트에서 수정 가능
- 인증 토큰 위조 시 로그인 우회 가능
- 사용자 권한 정보 조작 위험
- 서버 측 검증 절차 부재 시 보안 취약
- 민감 정보 노출 시 중간자 공격(MITM)에 취약

대응 방안

- 민감한 인증 정보는 LocalStorage에 저장하지 않음
- 서버 측 세션 기반 인증 또는 서명된 JWT 토큰 사용
- 클라이언트로부터 전달된 토큰의 유효성 및 무결성 서버에서 검증
- 모든 요청 시 권한 재확인 (role 정보 서버 검증)
- 토큰 탈취 방지를 위한 SameSite, Secure 플래그 설정
- 토큰 수명 제한 및 주기적 재발급(Refresh Token 전략 활용)
- CORS 정책 설정으로 신뢰된 출처에서만 접근 허용
- 사용자 입력값 필터링 및 검증으로 인젝션 방지
- 브라우저 저장소 접근 제어 불가하므로 서버 중심 보안 설계 필요

VI 회고 및 총평



1 기술적 개선 및 확장 방향

기술적 개선사항	상세 설명
DRM(디지털 권리 관리) 기능 도입	◆ 현재는 DRM 미적용 상태로, 음원의 무단 복제 및 배포를 막기 위한 강력한 DRM 시스템 도입이 필요합니다. ◆ 업계 표준 DRM 솔루션 또는 자체 암호화 방식을 연구 및 적용하여 음원 보호 강화.
클라우드 기반 자동 확장 및 부하 분산	◆ 트래픽 급증 시 자동으로 서버를 확장할 수 있는 클라우드 오토스케일링 및 로드밸런싱 체계 도입으로 안정성 향상. ◆ 멀티 리전 분산 배포를 통해 글로벌 서비스 대응력 강화.
보안 자동화 및 AI 기반 이상 탐지	◆ OAuth2, OpenID Connect 같은 표준 인증 체계 도입으로 보안 강화 및 확장성 확보. ◆ 2단계 인증(2FA) 및 비밀번호 정책 강화 등 사용자 계정 보호 강화.
사용자 인증 및 권한 관리 고도화	◆ 웹뿐 아니라 iOS, Android 등 다양한 플랫폼에서 일관된 사용자 경험과 보안 체계 제공. ◆ 앱 내 오프라인 재생, 다운로드 권한 관리 등 기능 확대.
모바일 및 다양한 클라이언트 지원 확대	◆ 웹뿐 아니라 iOS, Android 등 다양한 플랫폼에서 일관된 사용자 경험과 보안 체계 제공. ◆ 앱 내 오프라인 재생, 다운로드 권한 관리 등 기능 확대.
서비스 운영 자동화 및 DevSecOps 도입	◆ CI/CD 파이프라인 내 보안 검사 자동화 도구 통합. ◆ 인프라 코드 관리(IaC)로 안정적 운영과 보안 패치 신속 적용.

2

팀원별 회고

팀원 목록	회고 내용
강인석	이번 프로젝트를 통해서 전문용어도 많이 들어보고 실무적인 관점에서 고려해야하는 사항에 대해서 고민을 해볼 수 있었다. 시간이 남았으면 splunk 에서 알람을 제공하는 기능도 추가해보면 좋겠다고 생각했고, 인프라는 넓게 봐야한다는 생각을 가졌다. 2주차부터 집중이 잘 못해서 개인적으로 아쉬움이 많이 남는다.
남소현	이번 프로젝트를 통해 실제 서비스 환경과 유사한 인프라를 구성하고 보안 위협에 대응하는 전 과정을 실습할 수 있었습니다. 저는 웹 서버부터 API, DB, NFS 서버를 분리 구성하고 WAF 및 Snort 를 통한 공격 탐지까지 연동하여 보안 아키텍처의 흐름을 이해하게 되었습니다. 또한 Spring Boot 기반 웹페이지와 Flask API 를 연결하고 암호화·인젝션 방지 등 주요 보안 로직을 직접 구현하며 실무 역량을 키울 수 있었습니다. 보안 설계와 운영의 중요성을 체감하며 통합 보안 구축 경험을 쌓을 수 있어 유익한 시간이었습니다.
최현일	이 프로젝트2에서 시스템 보안의 중요성을 다시 한번 실감할 수 있었고, 실제 공격 시나리오를 경험하면서 이론과 실무를 연결하는 소중한 기회가 되었습니다. 앞으로는 자동화된 보안 정책 관리와 더 정교한 로그 분석 기술을 익혀, 더욱 효과적인 보안 체계를 구축하는 데 역량을 키우고자 했고, 이번 경험을 통해 팀 내에서 보안 전문가로서의 역할을 확고히 하고, 프로젝트 전반의 안정성과 신뢰성을 높이는 데 기여할 수 있어 매우 뜻깊었습니다.

감사합니다.



별첨

1단계	3.2.1 인증 흐름 설계	100%	100%	100%	강인석	2025-05-21	2025-05-23	3		
1단계	3.2.2 접근 통제 설계	100%	100%	100%	강인석	2025-05-22	2025-05-23	2		웹은 공개, API/DB는 내부망, 포트제어
1단계	3.2.3 공격 행위 탐지 설계	100%	100%	100%	강인석	2025-05-21	2025-05-23	3		SQLi 시도, XSS 입력, 다량 다운로드 감지 (Splunk)
1단계	3.2.4 로그 기반 대응	100%	100%	100%	강인석	2025-05-22	2025-05-23	2		Splunk로 로그 수집 및 대시보드 시각화, 알림 설정
1단계	(4) 시스템 구성도 및 자료 제작					2025-05-22	2025-05-23	2		시스템 구성도
1단계	4.1 시각화 자료 작성									
1단계	4.1.1 아키텍처 구성도 제작	100%	100%	100%	ALL	2025-05-22	2025-05-23	2		
1단계	4.1.2 보안 아키텍처 다이어그램	100%	100%	100%	ALL	2025-05-22	2025-05-23	2		
1단계	4.1.3 네트워크 흐름도 작성	100%	100%	100%	ALL	2025-05-22	2025-05-23	2		
2단계	(5) 시스템 구축					2025-05-26	2025-05-30	5		
2단계	5.1 서버 구축									
2단계	5.1.1 웹 서버 구축	100%	100%	100%	남소현	2025-05-26	2025-05-28	3		
2단계	5.1.2 API 서버 구축	100%	100%	100%	남소현	2025-05-26	2025-05-28	3		
2단계	5.1.3 DB 서버 구축	100%	100%	100%	남소현	2025-05-26	2025-05-28	3		
2단계	5.1.4 WAF 서버 구축	100%	100%	100%	남소현	2025-05-29	2025-05-29	1		
2단계	5.1.5 음원 저장 서버 구축	100%	100%	100%	최현일	2025-05-28	2025-05-29	2		
2단계	5.1.6 로그 수집 서버 구축	100%	100%	100%	강인석	2025-05-28	2025-05-29	2		
2단계	5.1.7 공격자 테스트 서버 구축	100%	100%	100%	최현일	2025-05-26	2025-05-26	1		
2단계	5.1.8 레포지토리 서버 구축	100%	100%	100%	최현일	2025-05-30	2025-05-30	1		
2단계	5.2 인프라 구축									
2단계	5.2.1 ESXi 기반 가상화 환경 구성	100%	100%	100%	강인석	2025-05-26	2025-06-04	8		
2단계	5.2.2 네트워크 구성 및 망 분리	100%	100%	100%	강인석	2025-05-26	2025-06-06	10		
2단계	5.2.3 서버 간 통신 설정 및 포트 제어	100%	100%	100%	강인석	2025-05-26	2025-05-27	2		
2단계	5.2.4 로그 수집 인프라 구축	100%	100%	100%	강인석	2025-05-27	2025-05-27	1		
2단계	5.2.5 외부 접속 및 협업 환경 구성	100%	100%	100%	최현일	2025-05-27	2025-05-29	3		
2단계	(6) 보안 시스템 고도화					2025-05-30	2025-06-10	6		
2단계	6.1 기술적 고도화									
2단계	6.1.1 서버 및 애플리케이션 보안 패치 적용	100%	100%	100%	강인석	2025-06-06	2025-06-06	1		ClamAV, Aiyac Linu설치 및 구성
2단계	6.1.2 데이터 암호화 솔루션 적용	100%	100%	100%	남소현	2025-05-30	2025-05-30	1		
2단계	6.1.3 데이터 백업 및 복구 시스템 점검	100%	100%	100%	ALL	2025-06-02	2025-06-02	1		ESXi 백업 및 VM 개별 스냅샷
2단계	6.1.4 방화벽 정책 최신화	100%	100%	100%	강인석	2025-06-10	2025-06-10	1		방화벽 rich rule 정책적용
2단계	6.2 운영 및 관리 고도화									
2단계	6.2.1 방화벽 정책 문서 업데이트	100%	100%	100%	강인석	2025-06-02	2025-06-10	7		인터넷 이스 불 방화벽 정책 Excel
2단계	6.2.2 실시간 알림 체계 구축	100%	100%	100%	강인석	2025-06-03	2025-06-03	1		
2단계	6.2.3 이벤트 우선순위 관리 정책	100%	100%	100%	강인석	2025-06-02	2025-06-04	3		
2단계	6.2.4 자산 정보 문서 업데이트	100%	100%	100%	ALL	2025-06-10	2025-06-10	1		SW 버전 정보
3단계	(7) ESM 구성					2025-06-05	2025-06-09	3		
3단계	7.1 splunk 대시보드 구성									
3단계	7.1.1 실시간 위협 탐지	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		
3단계	7.1.2 네트워크 트래픽 모니터링	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		
3단계	7.1.3 사용자 활동 분석	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		
3단계	7.1.4 시스템 상태 모니터링	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		

3단계	7.2 IPS, WAF 통합 모니터링 대시보드									
3단계	7.2.1 IPS, WAF 로그 수집	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		
3단계	7.2.2 통합 대시보드 생성	100%	100%	100%	ALL	2025-06-05	2025-06-09	3		
3단계	7.2.3 브라우저 플러그인 제작	100%	100%	100%	남소현	2025-06-05	2025-06-09	3		
3단계	7.2.4 특정 IP 차단 자동화	100%	100%	100%	강민석	2025-06-05	2025-06-06	2	6월4일	
3단계	(8) 시스템 구축 자료 수집					2025-05-26	2025-06-09	10		
3단계	8.1 구축 과정 기록									
3단계	8.1.1 서버별 구축	100%	100%	100%	ALL	2025-06-06	2025-06-06	1		
3단계	8.1.2 Splunk 대시보드 구축	100%	100%	100%	ALL	2025-06-06	2025-06-06	1		
3단계	8.1.3 Kali 공격 환경	100%	100%	100%	ALL	2025-05-26	2025-05-26	1		
3단계	8.2 로그 및 결과 수집									
3단계	8.2.1 시스템 로그 수집	100%	100%	100%	강민석	2025-06-09	2025-06-09	1		
3단계	8.2.2 웹 서비스 로그 수집	100%	100%	100%	남소현	2025-06-09	2025-06-09	1		
3단계	8.2.3 사용자 행동 로그 수집	100%	100%	100%	ALL	2025-06-09	2025-06-09	1		
3단계	8.2.4 공격 관련 로그 수집	100%	100%	100%	ALL	2025-06-09	2025-06-09	1		
3단계	8.2.5 Splunk 탐지 결과 수집	100%	100%	100%	ALL	2025-06-09	2025-06-09	1		
3단계	8.2.6 공격자 로그 수집	100%	100%	100%	ALL	2025-06-09	2025-06-09	1		
3단계	(9) 프로젝트 완료 보고서 작성					2025-06-09	2025-06-10	2		
3단계	9.1 보고서 내용 요약									
3단계	9.1.1 프로젝트 개요	100%	100%	100%	ALL	2025-06-09	2025-06-10	2		
3단계	9.1.2 아키텍처 설계	100%	100%	100%	ALL	2025-06-09	2025-06-10	2		
3단계	9.1.3 주요 기능 및 기술	100%	100%	100%	ALL	2025-06-09	2025-06-10	2		
3단계	9.1.4 공격 - 방어 결과	100%	100%	100%	ALL	2025-06-09	2025-06-10	2		
3단계	9.1.5 결과 정리 및 회고	100%	100%	100%	ALL	2025-06-09	2025-06-10	2		

250520 3조 회의록

무료음원제공 서비스 < 소리공간 >

운영체제: Rocky Linux / Kail Linux / Ubuntu

✅ 웹서버 기능

1. 회원가입/로그인
2. 음악 검색
3. 음악 스트리밍
 - YouTube DOVA-SYNDROME YouTube Official
 - 음원 파일에 DRM 적용
4. 음악 다운로드

✅ 구축할 서버

1. WEB 서버
 2. API 서버
 3. DB 서버
 4. 음원 저장 서버
 5. 로그 수집/대시보드 (splunk, zabbix?, log4j?, Gitlab 모니터링?, Jenkins 로그?, sftp log)
 6. 공격자 테스트 서버
 7. DNS 서버
- 팀장은 ESXi VM 관리 전담
 - 팀원은 VPN이나 다른 방법으로 접속 후 도메인 기반으로 작업 수행
 - 화이트리스트 방식 접근 허용 적용 예정
 - 23일 부터 구축 시작 예정

250521 3조 회의록

무료음원제공 서비스 < 소리공간 >

운영체제: Rocky Linux / Kail Linux / Ubuntu

✅ UTM

1. OPNsense 사용 - 기존의 pfsense 이외의 오픈소스 활용
2. 리스트

프로젝트 진행 역할 분배

- 센터를 3개로 나눠서 진행

[A 센터] - 운영 서비스 담당

- WEB/WAS/DB 각각의 서비스를 담당.
- 파일 저장 서버를 통한 SFTP 통신
- 웹 방화벽(modsecurity) 구축

[B센터] - 로그 분석

- SPLUNK, IDS 로그 분석
- 시스템 모니터링 및 로그 관리

[C센터] - 사이버 공격 테스트

- 시나리오 기반 공격 테스트
- 취약점 점검

⇒ 각 센터에서 기능에 따른 분류 미흡, C센터의 경우 내부 서버가 1대밖에 없는 점, 내일 상의 예정

250522 3조 회의록

무료음원제공 서비스 < 소리곳간 >

운영체제: Rocky Linux / Kail Linux / Ubuntu

[A센터] - SFTP

- 운영자가 음원 업로드를 위한 사용(외부 사용자 X)
- API 방식으로 음원 다운로드 제공
 - NFS 서버를 mount 하여 활용
 - SFTP 의 경우 SSH 접속 로그 포함 → access log 에서 확인 가능
- ClamAV → 웹 서버에 설치 예정(추후 자원에 따라 다른 서버에서 설치)

[B센터] - 자원 이슈

- Security Onion 의 최소 메모리 8GB 이므로 2개 설치 어려움으로 제거

[C센터] - 테스트 서버

- Gitlab, jenkins 등 CI/CD 서버의 경우 추후에 추가 예정

250523 3조 회의록

[감사님 수정 권고사항]

구성도OPNsense UI 를 개선

- 어느정도 어려운지 확인해보고 pfsense 로 수정
- 의사결정 시기(날짜)를 미리 정해두기
- 공격 방어에 집중해야함.

A센터 게이트웨이 IP 설정

vSwitch 에 대한 네이밍 변경

시스템 보안

- B센터 영역의 시스템 보안 개선 필요

오피스 대역

- 웹 필터
- clam AV 등 백신
- 키로깅

[개선 사항]

OPNsense 사용에 대한 의사 결정 기간 정하기.

B센터 영역의 시스템 보안 개선

250526 3조 회의록

[오전]

- 미비한 아키텍처 설계도 완성
- DRM 사용 유무 판단
 - 시간이 오래 소요될 것으로 생각
 - 어떻게 구성할 지에 대한 구체적인 방안 X
 - ⇒ DRM 사용 X 결정
- 비밀번호나 개인정보 암호화 적용

[오후]

- 아키텍처 기반으로 구현
- 3개의 역할로 분배
 - 소현 : 스트리밍 서비스 웹 사이트 제작
 - 현일 : 서버 설치(칼리, NFS 등)
 - 인석 : UTM 설치

250527 3조 회의록

[오전]

- 리스트

[오후]

- OPNsense → pfsense로 변경

☰ 진행사항 +

☰ ⏶ ⏷ 🔍 ↺ ⏸

새로 만들기 ▾

Aa 이름

☰ 작업내용

☼ 상태

+

(팀장)  열기

- ✓ A센터 pfsense 설치 및 네트워크 설정 완료
- ✓ B센터 pfsense 설치 中

● 진행 중

(팀원) 최현일

- ✓ NFS서버 1EA, 공격 테스트용 Kali Linux 2EA
- ✓ 관리자 PC, SFTP서버 진행중

● 진행 중

(팀원) 남소현

- ✓ 웹서버 + DB 서버 + API서버 + (임시)NFS서버 연동완료
- ✓ 웹서버 검색 기능 진행중...

● 진행 중

+ 새 페이지

250528 3조 회의록

☰ 진행사항

☰ ⬆ ⬇ 🔍 ↶ ⚙

새로 만들기 ▼

Aa 이름

☰ 작업내용

☀ 상태

+

(팀원) 남소현
✅ http to https 완료 및 서버 업로드 완료
✅ nfs ↔ api 마운트 설정 후 정상 서비스 확인

● 진행 중

(팀장) 강인석
- pfSense 간 IPsec 연결 완료
- A-DNS 설치 중
- A-WAF 설치 완료 & 테스트 필요
- B-splunk 설치 중

● 진행 중

(팀원) 최현일
✅ 관리자 PC, SFTP서버 완료
✅ Alyac linux 설치중

● 진행 중

250529 3조 회의록

☰ 진행사항

Aa 이름

☰ 작업내용

☐

(팀장) ? ☐ 열기

A센터 → B센터 로그 전송 실패
11.x.x.x 대역은 private 대역으로 사용 불가
B-UFW IP 주소 변경 예정 11.10.1.x → 192.168.x.x

(팀원) 최현일
- 칼리리눅스 2대 알락리눅스 설치 및 실행
- pfSense snort 설정

(팀원) 남소현
- A-WAF 설정 완료 > 차단 및 로그 생성 확인
- API ↔ NFS 연동 실패 (아이피 오류) 해결
- WAF → WEB 거치도록 연동 및 도메인 완료
- 웹서버에 알락리눅스 설치 및 실행

250530 3조 회의록

(팀장) <u>강인석</u>		진행 중
(팀원) <u>최현일</u>	- 레포지토리 서버 설치 및 설정 - pfsense snort 설정 완료	진행 중
(팀원) <u>남소현</u>		진행 중

250602 3조 회의록

☞ 진행사항

☰ ↓

Aa 이름

☰ 작업내용

(팀장) 강인석

- splunkforwarder 연동
- snoopy 설치
- IPsec VPN 설정

(팀원) 남소현

- splunkforwarder WEB/DB/API
- B Center DNS Setting
- snoopy

(팀원) 최현일

- External 관리자 PC 설치 및 설정
- Repository 서버 설정 및 관리자 PC 테스트
- pfsense 정책 테스트

250604 3조 회의록

☰ 진행사항

☰ ⏴ ⏵ 🔍 ↺ ⚙️ 새로

Aa 이름

☰ 작업내용

☼ 상태

(팀원) 남소현

- 공격 시나리오 설정
- 취약점있도록 코드 수정
- [sorigotgan.com](#) 접속 공격 테스트

● 진행 중

(팀원) 최현일

- 공격 시나리오 설정
- [sorigotgan.com](#) 웹취약점 테스트

● 진행 중

(팀장) 강인석

- 공격 시나리오 설정
- security onion 설치
- Admin 서버 → VPN 설정하여 각 서버 접근 가능

● 진행 중

250605 3조 회의록

☰ 진행사항

Aa 이름

☰ 작업내용

(팀장) 강인석

- Splunk 대시보드 작성

(팀원) 남소현

- Splunk 대시보드 작성
- 공격 테스트

(팀원) 최현일

- Splunk 대시보드 작성

250609 3조 회의록

☞ 진행사항

☰ ↓ ↻ 🔍 ↗ ⚙

새로 만들기 ▼

Aa 이름	≡ 작업내용	☼ 상태	+
(팀원) 남소현	- 공격 시나리오 실습 (인젝션, brute-force, localstorage 위조, credential stuffing(유출되었다고 가정) 그외의 취약점 점검) - splunk 대시보드 추가	● 진행 중	
(팀장) 강인석	- 공격 시나리오 따른 실습 - OWASP ZAP 점검 - 취약점 점검 → 웹 서버 대상	● 진행 중	
(팀원) 최현일		● 진행 중	